LEK-VORBEREITUNG · DATENSCHUTZ

Übungsfragen mit Lösungsblatt

21 Aufgaben aus Kapitel 1 bis 3 · Lösungsblatt mit Begründungen ab Seite 6

KAPITEL 1
Was ist Datenschutz?
Aufgaben 13–17 · 5 Fragen

KAPITEL 2
Grundsätze im Datenschutz
Aufgaben 30–37 · 8 Fragen

KAPITEL 3
Wichtige Einzelthemen
Aufgaben 17–24 · 8 Fragen

Name _____ Datum _____ Punkte _____ / 21

Kreuze alle zutreffenden Antworten an – bei einigen Aufgaben sind mehrere Antworten richtig. Ein Punkt pro Aufgabe, wenn alle Kreuze stimmen. Die Aufgabennummern entsprechen den Original-Übungsblättern.

KAPITEL 1 · AUFGABEN 13–17

Was ist Datenschutz?

13 **Welche der folgenden Aussagen ist falsch?**

- ☐ A Die DSGVO beschäftigt sich überwiegend mit Datenschutz, enthält aber auch Vorschriften zur Datensicherheit.
- ☐ B Beim Datenschutz geht es um die Grundrechte und Grundfreiheiten von natürlichen Personen.
- ☐ C Datensicherheit beschäftigt sich überwiegend mit dem Schutz von Geschäftsgeheimnissen.
- ☐ D Die Schnittmenge von Datenschutz und Datensicherheit sind die sogenannten technisch organisatorischen Maßnahmen (TOM).

14 **Welche beiden Aussagen zu den gesetzlichen Grundlagen des Datenschutzes sind korrekt?**

- ☐ A Die DSGVO gilt ausschließlich für Unternehmen, nicht für die öffentlichen Stellen des Bundes.
- ☐ B Die DSGVO gilt als europäisches Recht in jedem Mitgliedsland der EU. Die nationalen Parlamente (in Deutschland der Bundestag) mussten der DSGVO nicht zustimmen.
- ☐ C In Deutschland enthalten neben dem BDSG und der DSGVO noch zahlreiche weitere Gesetze Vorschriften zum Datenschutz.
- ☐ D Das Bundesdatenschutzgesetz gilt ausschließlich für öffentliche Stellen.

15 Ein kanadischer Konzern möchte seine Produkte online in Ländern des Europäischen Wirtschaftsraumes (EWR) anbieten. Er lässt dazu Onlineshops in Englisch, Deutsch und Französisch entwickeln, welche in einem Rechenzentrum in Südafrika gehostet sind.

Welche Aussage in Bezug auf den Datenschutz ist richtig?

- ☐ A Die Regeln der DSGVO müssen nicht beachtet werden, da der Sitz des Unternehmens in Kanada liegt und der Online-Shop über Südafrika läuft.
- ☐ B Da der Konzern seinen Sitz in Kanada hat, müssen die kanadischen Datenschutzgesetze beachtet werden, die DSGVO muss daher nicht einbezogen werden.
- ☐ C Da der Onlineshop sich an Kunden (betroffene Personen) in Europa richtet, müssen alle Vorgaben der DSGVO beachtet werden.

16 **Was sind personenbezogene Daten?**

- ☐ A Nur Daten, die eine identifizierte Person bezeichnen.
- ☐ B Ausschließlich Namen, Adresse und Kontaktdaten, da diese Daten die Person direkt bezeichnen.
- ☐ C Alle Daten, die ständig verfügbar sein müssen und eine natürliche Person betreffen.
- ☐ D Alle Daten, von denen man direkt oder indirekt eine natürliche Person ermitteln kann.

17 **Wer ist bei einer verantwortlichen Stelle immer für die Einhaltung der Datenschutzvorschriften verantwortlich?**

- ☐ A Der Datenschutzbeauftragte
- ☐ B Der Abteilungsleiter, in dessen Abteilung die Daten verarbeitet werden
- ☐ C Die oberste Leitungsebene

KAPITEL 2 · AUFGABEN 30–37

Grundsätze im Datenschutz

30 **Welche Risikoansätze werden bei der Verarbeitung personenbezogener Daten nach DSGVO im Vergleich zur allgemeinen IT verfolgt?**

- ☐ A Es gibt keinen Unterschied, da beide die gleiche Formel zur Berechnung des Risikoausmaßes verwenden.
- ☐ B Der Datenschutz nach DSGVO betrachtet die qualitativen Risiken, denen die Rechte und Freiheiten natürlicher Personen ausgesetzt sind. Diesen Risiken liegen keine direkt quantifizierbaren Werte zugrunde – sie müssen kategorisiert werden.
- ☐ C Die allgemeine IT verfolgt einen quantifizierbaren Ansatz, bei dem die Schadenshöhe und die Eintrittswahrscheinlichkeit zum Einsatz kommen.

31 **Was versteht man im Datenschutz unter einer Schutzbedarfsanalyse?**

- ☐ A Die Methode, wie alle Informationen im Unternehmen abgesichert werden müssen.
- ☐ B Bildung von Schutzbedarfskategorien aus einer Risikoanalyse über personenbezogene Daten.
- ☐ C Die Beschreibung welche Technisch-Organisatorische Maßnahme zu welchem Risiko passt.

32 **Welche der folgenden Daten zählen nicht zu den „Daten besonderer Kategorie“ nach Art. 9 DSGVO wie z. B. Gesundheitsdaten?**

- ☐ A Bankdaten
- ☐ B Biometrische Daten
- ☐ C Religiöse Überzeugung
- ☐ D Polizeiliches Führungszeugnis

33 **Welche der folgenden Rechte sind keine Betroffenenrechte gemäß DSGVO?**

- ☐ A Recht auf Berichtigung
- ☐ B Recht auf Verschlüsselung
- ☐ C Recht auf Einschränkung der Verarbeitung
- ☐ D Recht auf Anonymisierung

34 **Welche beiden der folgenden Aussagen sind falsch? Das Auskunftsrecht nach DSGVO ...**

- ☐ A ... gilt nur gegenüber Behörden, nicht gegenüber Privatunternehmen.
- ☐ B ... wird durch die Aufsichtsbehörde ausgeübt.
- ☐ C ... schließt das Recht auf eine Kopie der Daten ein.
- ☐ D ... kann bei exzessiver Nutzung verweigert werden.

35 Die besonderen Kategorien des Art. 9 DSGVO wie z. B. biometrische Daten bezeichnen besonders schützenswerte personenbezogene Daten und untersagen grundsätzlich die Verarbeitung der bezeichneten Daten/Informationen. Es gibt aber Ausnahmen.

Welche Aussagen sind richtig?

- ☐ A Die Einwilligung der betroffenen Person liegt in rechtsgültiger Form vor.
- ☐ B Die Datenverarbeitung dient dem berechtigten Interesse der Verantwortlichen Stelle.
- ☐ C Die Verarbeitung ist aus arbeits- und sozialrechtlichen Gründen notwendig.
- ☐ D Die Verarbeitung dient zur Vertragserfüllung und -anbahnung oder eines Arbeitsvertrages.

36 **Welches ist im normalen Geschäftsbereich die sicherste und stärkste Rechtsgrundlage für die Verarbeitung personenbezogener Daten?**

- ☐ A Die Einwilligung, weil die von der betroffenen Person bewusst gegeben werden muss.
- ☐ B Berechtigte Interessen, weil die am breitesten ausgelegt werden können.
- ☐ C Ein Vertrag, der auf Anfrage der betroffenen Person zustande kommt.

37 Gemäß dem Grundsatz der Datensparsamkeit dürfen nach DSGVO nur die für die Zweckerfüllung benötigten Daten erhoben und verarbeitet werden.

Als Fachinformatiker haben Sie die Aufgabe, für einen Online-Büchershop eine entsprechende Eingabemaske zu entwerfen.

Die Maske soll zusätzlich zum Namen, zu Kontakt- und Zahlungsdaten noch Daten zum Einkommen, Alter und Familienstand enthalten.

Wie muss die Eingabemaske konditioniert werden?

- ☐ A Alle Eingabefelder können als Pflichtfelder deklariert werden, da die Daten auch anderweitig verwendet werden können.
- ☐ B Es müssen keine Pflichtfelder gekennzeichnet werden, damit die Kunden zum Ausfüllen aller Felder motiviert werden.
- ☐ C Nur die für den Verkauf benötigten Daten dürfen als Pflichtfelder gekennzeichnet werden, die anderen müssen als optional erkennbar sein.

KAPITEL 3 · AUFGABEN 17–24

Wichtige Einzelthemen

17 **Welche der folgenden Aussagen ist richtig?**

- ☐ A Das Urheberrecht gilt nur für Werke der Musik und der bildenden Kunst, nicht aber für Computerprogramme.
- ☐ B Das Urheberrecht wird erst mit der Veröffentlichung des Werkes wirksam.
- ☐ C Das Urheberrecht erlischt 70 Jahre nach dem Tod des Urhebers.
- ☐ D Urheberrecht kann nur für Werke in Anspruch genommen werden, die mit dem Copyright-Zeichen © gekennzeichnet sind.

18 **Damit eine natürliche oder juristische Person als „Verantwortlicher" oder „verantwortliche Stelle" gilt, muss sie Entscheidungsgewalt über zwei Dinge haben:**

- ☐ A Zeitpunkt und Art der Daten
- ☐ B Erhebung und Verwendung der personenbezogenen Daten
- ☐ C Mittel und Zweck der Verarbeitung von personenbezogenen Daten
- ☐ D Organisieren und Auslesen von personenbezogenen Daten

19 **Kennzeichnen Sie die falsche Aussage in Bezug auf ein Verzeichnis der Verarbeitungstätigkeiten (VVT).**

- ☐ A Die meisten Unternehmen sind zum Erstellen eines VVT verpflichtet.
- ☐ B Ein fehlendes VVT kann zur Verhängung eines Bußgeldes führen.
- ☐ C Die Mindestinhalte des VVT sind in der DSGVO definiert, die Form des VVT hingegen nicht.
- ☐ D Das VVT muss der Aufsichtsbehörde spätestens zum 2. Quartal eines jeden Jahres unaufgefordert vorgelegt werden.

20 **Um im Unternehmen herauszufinden, was die Rechtsgrundlage und was die Löschfrist für die Arbeitszeiterfassung ist, wird welches Dokument diese Angaben enthalten?**

- ☐ A Personalakte
- ☐ B Stellenbeschreibung des Mitarbeiters
- ☐ C Tätigkeitsbericht des DSB
- ☐ D Verzeichnis der Verarbeitungstätigkeiten (VVT)

21 Die Verarbeitung personenbezogener Daten darf nur zweckgebunden erfolgen. Nach der Zweckerfüllung darf auch keine Identifizierung der betroffenen Person mehr möglich sein.

Welche Aussagen sind richtig?

- ☐ A Nach der Zweckerfüllung müssen die personenbezogenen Daten sofort gelöscht oder anonymisiert werden, wenn keine gesetzlichen Regelungen entgegenstehen.
- ☐ B Wenn die gesetzliche Aufbewahrungsfrist noch nicht abgelaufen ist, bleiben die Daten gespeichert, müssen aber nach der Zweckerfüllung durch ein geeignetes Verfahren dem allgemeinen Zugriff entzogen werden.
- ☐ C Solange die gesetzliche Aufbewahrungsfrist läuft, bleiben die Daten unverändert gespeichert, damit sie jederzeit eingesehen werden können.

22 **Wann spricht man von einer Auftragsverarbeitung?**

- ☐ **A** Wenn ein Unternehmen die Daten von einer dritten Stelle bekommt und sie für eigene Zwecke verarbeitet.
- ☐ **B** Wenn ein weiteres Unternehmen über Mittel und Zwecke der Verarbeitung entscheidet.
- ☐ **C** Wenn eine natürliche oder juristische Person, Behörde oder Einrichtung personenbezogene Daten im Auftrag für den Verantwortlichen (dieser Daten) verarbeitet.

23 Die DSGVO enthält keine detaillierten Regelungen zur Verarbeitung von personenbezogenen Daten für Werbezwecke. Diese sind explizit im Gesetz gegen den unlauteren Wettbewerb (UWG) formuliert.

Welche Aussage ist richtig?

- ☐ **A** Da das UWG ein nationales deutsches Gesetz ist, müssen die Vorgaben der DSGVO im Hinblick auf Datenerhebung und Informationspflichten nicht beachtet werden.
- ☐ **B** Sobald es sich gem. UWG um Bestandskunden handelt, darf ich Werbung zustellen und muss nichts weiter beachten.
- ☐ **C** Zusätzlich zu den Erlaubnistatbeständen des UWG müssen die Informationspflichten der DSGVO erfüllt werden.

24 **Innerhalb welches Zeitraums nach Bekanntwerden muss die verantwortliche Stelle meldepflichtige Datenschutzverstöße der Aufsichtsbehörde melden?**

- ☐ **A** Innerhalb 1 Monats
- ☐ **B** Innerhalb von 72 Stunden
- ☐ **C** Innerhalb von 3 Monaten

TEIL B

Lösungsblatt

Lösungen laut den Lösungsblättern zu Kapitel 1–3, jeweils mit Begründung und Rechtsgrundlage.

☑ **richtige Aussage** – ankreuzen

☑ **falsche Aussage** – ankreuzen, weil nach „falsch", „nicht" oder „keine" gefragt ist

Lösungsschlüssel auf einen Blick

AUFGABE	LÖSUNG	MERKPUNKT
Kapitel 1 · Was ist Datenschutz?		
13	C Negativfrage	Datensicherheit schützt **alle** Daten – nicht überwiegend Geschäftsgeheimnisse
14	B, C	DSGVO gilt unmittelbar (Verordnung); viele weitere Gesetze enthalten Datenschutzregeln
15	C	Marktortprinzip – Art. 3 Abs. 2 DSGVO
16	D	direkt oder indirekt identifizierbar – Art. 4 Nr. 1 DSGVO
17	C	oberste Leitungsebene – nicht der DSB
Kapitel 2 · Grundsätze im Datenschutz		
30	B, C	DSGVO qualitativ (Sicht der Betroffenen) · IT quantitativ (Schaden × Wahrscheinlichkeit)
31	B	Schutzbedarfskategorien aus der Risikoanalyse
32	A, D Negativfrage	Bankdaten = „normale" Daten · Führungszeugnis = Art. 10 DSGVO
33	B, D Negativfrage	Verschlüsselung und Anonymisierung sind TOM, keine Rechte
34	A, B Negativfrage	Auskunft gilt gegenüber jedem Verantwortlichen und wird vom Betroffenen selbst geltend gemacht
35	A, C	Art. 9 Abs. 2 lit. a (Einwilligung) und lit. b (Arbeits- und Sozialrecht)
36	C	Vertrag – Art. 6 Abs. 1 lit. b DSGVO
37	C	nur Notwendiges als Pflichtfeld, der Rest erkennbar optional
Kapitel 3 · Wichtige Einzelthemen		
17	C	70 Jahre nach dem Tod des Urhebers – § 64 UrhG
18	C	Zwecke und Mittel – Art. 4 Nr. 7 DSGVO
19	D Negativfrage	VVT nur auf Anfrage an die Aufsichtsbehörde – Art. 30 Abs. 4
20	D	Verzeichnis der Verarbeitungstätigkeiten (VVT)
21	A, B	Zweck erfüllt: löschen/anonymisieren – bei laufender Aufbewahrungsfrist sperren
22	C	Verarbeitung im Auftrag – Art. 4 Nr. 8, Art. 28 DSGVO
23	C	UWG und DSGVO gelten nebeneinander
24	B	72 Stunden – Art. 33 Abs. 1 DSGVO

KAPITEL 1 · AUFGABEN 13–17

Was ist Datenschutz?

13 **Welche der folgenden Aussagen ist falsch?**

- ☐ A Die DSGVO beschäftigt sich überwiegend mit Datenschutz, enthält aber auch Vorschriften zur Datensicherheit.
- ☐ B Beim Datenschutz geht es um die Grundrechte und Grundfreiheiten von natürlichen Personen.
- ☑ C **Datensicherheit beschäftigt sich überwiegend mit dem Schutz von Geschäftsgeheimnissen.**
- ☐ D Die Schnittmenge von Datenschutz und Datensicherheit sind die sogenannten technisch organisatorischen Maßnahmen (TOM).

BEGRÜNDUNG

Gesucht ist die falsche Aussage – das ist C. Datensicherheit schützt **alle Daten** (personenbezogen oder nicht) vor Verlust, Manipulation und unberechtigter Kenntnisnahme, also Vertraulichkeit, Integrität und Verfügbarkeit; Geschäftsgeheimnisse sind nur ein Teil davon. A, B und D stimmen: Die DSGVO regelt in **Art. 32 DSGVO** auch die Sicherheit der Verarbeitung, sie schützt die Grundrechte und Grundfreiheiten natürlicher Personen (**Art. 1 Abs. 2 DSGVO**), und die **TOM** bilden die Schnittmenge beider Bereiche.

14 **Welche beiden Aussagen zu den gesetzlichen Grundlagen des Datenschutzes sind korrekt?**

- ☐ A Die DSGVO gilt ausschließlich für Unternehmen, nicht für die öffentlichen Stellen des Bundes.
- ☑ B **Die DSGVO gilt als europäisches Recht in jedem Mitgliedsland der EU. Die nationalen Parlamente (in Deutschland der Bundestag) mussten der DSGVO nicht zustimmen.**
- ☑ C **In Deutschland enthalten neben dem BDSG und der DSGVO noch zahlreiche weitere Gesetze Vorschriften zum Datenschutz.**
- ☐ D Das Bundesdatenschutzgesetz gilt ausschließlich für öffentliche Stellen.

BEGRÜNDUNG

Die DSGVO ist eine EU-**Verordnung** und gilt nach **Art. 288 AEUV** unmittelbar in allen Mitgliedstaaten – anders als eine Richtlinie braucht sie kein Umsetzungsgesetz und keine Zustimmung des Bundestags. Datenschutzregeln stehen außerdem in vielen weiteren Gesetzen, z. B. im **TDDDG**, im Sozialgesetzbuch oder im Kunsturhebergesetz. Falsch sind A und D: Die DSGVO gilt auch für Behörden, und das BDSG gilt für öffentliche **und** nichtöffentliche Stellen (**§ 1 Abs. 1 BDSG**).

15 Ein kanadischer Konzern möchte seine Produkte online in Ländern des Europäischen Wirtschaftsraumes (EWR) anbieten. Er lässt dazu Onlineshops in Englisch, Deutsch und Französisch entwickeln, welche in einem Rechenzentrum in Südafrika gehostet sind.

Welche Aussage in Bezug auf den Datenschutz ist richtig?

- ☐ A Die Regeln der DSGVO müssen nicht beachtet werden, da der Sitz des Unternehmens in Kanada liegt und der Online-Shop über Südafrika läuft.
- ☐ B Da der Konzern seinen Sitz in Kanada hat, müssen die kanadischen Datenschutzgesetze beachtet werden, die DSGVO muss daher nicht einbezogen werden.
- ☑ C **Da der Onlineshop sich an Kunden (betroffene Personen) in Europa richtet, müssen alle Vorgaben der DSGVO beachtet werden.**

BEGRÜNDUNG

Marktortprinzip (Art. 3 Abs. 2 lit. a DSGVO): Die DSGVO gilt auch für Unternehmen ohne Sitz in der EU, wenn sie Personen in der EU Waren oder Dienstleistungen anbieten – hier erkennbar an den Shops auf Deutsch und Französisch für den EWR (über das EWR-Abkommen gilt die DSGVO auch in Norwegen, Island und Liechtenstein). Firmensitz in Kanada und Server in Südafrika ändern daran nichts.

16 **Was sind personenbezogene Daten?**

- ☐ A Nur Daten, die eine identifizierte Person bezeichnen.
- ☐ B Ausschließlich Namen, Adresse und Kontaktdaten, da diese Daten die Person direkt bezeichnen.
- ☐ C Alle Daten, die ständig verfügbar sein müssen und eine natürliche Person betreffen.
- ☑ **D Alle Daten, von denen man direkt oder indirekt eine natürliche Person ermitteln kann.**

BEGRÜNDUNG

Definition in **Art. 4 Nr. 1 DSGVO**: alle Informationen, die sich auf eine **identifizierte oder identifizierbare** natürliche Person beziehen. Identifizierbar ist, wer **direkt oder indirekt** bestimmt werden kann, z. B. über eine Kennnummer, Standortdaten oder eine Online-Kennung wie die IP-Adresse. A und B sind zu eng, C nennt ein Merkmal (ständige Verfügbarkeit), das keine Rolle spielt.

17 **Wer ist bei einer verantwortlichen Stelle immer für die Einhaltung der Datenschutzvorschriften verantwortlich?**

- ☐ A Der Datenschutzbeauftragte
- ☐ B Der Abteilungsleiter, in dessen Abteilung die Daten verarbeitet werden
- ☑ **C Die oberste Leitungsebene**

BEGRÜNDUNG

Verantwortlich ist die verantwortliche Stelle selbst (**Art. 4 Nr. 7, Art. 24 DSGVO**) – und damit ihre oberste Leitung (Geschäftsführung, Vorstand, Behördenleitung). Sie trägt die **Rechenschaftspflicht** (**Art. 5 Abs. 2 DSGVO**). Der Datenschutzbeauftragte berät und überwacht nur (**Art. 39 DSGVO**); Abteilungsleiter können Aufgaben übernehmen, die Verantwortung bleibt aber bei der Leitung.

KAPITEL 2 · AUFGABEN 30–37

Grundsätze im Datenschutz

30 **Welche Risikoansätze werden bei der Verarbeitung personenbezogener Daten nach DSGVO im Vergleich zur allgemeinen IT verfolgt?**

- ☐ A Es gibt keinen Unterschied, da beide die gleiche Formel zur Berechnung des Risikoausmaßes verwenden.
- ☑ **B Der Datenschutz nach DSGVO betrachtet die qualitativen Risiken, denen die Rechte und Freiheiten natürlicher Personen ausgesetzt sind. Diesen Risiken liegen keine direkt quantifizierbaren Werte zugrunde – sie müssen kategorisiert werden.**
- ☑ **C Die allgemeine IT verfolgt einen quantifizierbaren Ansatz, bei dem die Schadenshöhe und die Eintrittswahrscheinlichkeit zum Einsatz kommen.**

BEGRÜNDUNG

Der Datenschutz bewertet das Risiko **für die betroffenen Personen** (Rechte und Freiheiten, **Art. 24, 32, 35 DSGVO**). Schäden wie Diskriminierung, Rufschädigung oder Identitätsdiebstahl lassen sich nicht in Euro beziffern, deshalb wird **qualitativ** in Kategorien eingestuft (z. B. geringes – normales – hohes Risiko). Die klassische IT-Sicherheit betrachtet das Risiko **für das Unternehmen** und rechnet **quantitativ**: Risiko = Schadenshöhe × Eintrittswahrscheinlichkeit. Auch die DSGVO fragt nach Eintrittswahrscheinlichkeit und Schwere (**EG 76**) – aber aus Sicht der Betroffenen und in Kategorien statt in Euro. A ist deshalb falsch.

31 **Was versteht man im Datenschutz unter einer Schutzbedarfsanalyse?**

- [ ] A Die Methode, wie alle Informationen im Unternehmen abgesichert werden müssen.
- [x] B Bildung von Schutzbedarfskategorien aus einer Risikoanalyse über personenbezogene Daten.
- [ ] C Die Beschreibung welche Technisch-Organisatorische Maßnahme zu welchem Risiko passt.

BEGRÜNDUNG
Aus der Risikoanalyse der Verarbeitung werden **Schutzbedarfskategorien** gebildet (z. B. normal – hoch – sehr hoch). Nach dem Schutzbedarf richtet sich anschließend, welche TOM nötig sind. A beschreibt die allgemeine Informationssicherheit (alle Informationen), C den nachgelagerten Schritt der Maßnahmenauswahl – nicht die Analyse selbst.

32 **Welche der folgenden Daten zählen nicht zu den „Daten besonderer Kategorie“ nach Art. 9 DSGVO wie z. B. Gesundheitsdaten?**

- [x] A Bankdaten
- [ ] B Biometrische Daten
- [ ] C Religiöse Überzeugung
- [x] D Polizeiliches Führungszeugnis

BEGRÜNDUNG
Gesucht sind die Daten, die **nicht** unter Art. 9 fallen: **Bankdaten** sind „normale“ personenbezogene Daten (wenn auch schutzwürdig), das **Führungszeugnis** enthält Daten über strafrechtliche Verurteilungen – dafür gilt der eigene **Art. 10 DSGVO**. Biometrische Daten (zur eindeutigen Identifizierung) und religiöse Überzeugungen stehen ausdrücklich in **Art. 9 Abs. 1 DSGVO**.

33 **Welche der folgenden Rechte sind keine Betroffenenrechte gemäß DSGVO?**

- [ ] A Recht auf Berichtigung
- [x] B Recht auf Verschlüsselung
- [ ] C Recht auf Einschränkung der Verarbeitung
- [x] D Recht auf Anonymisierung

BEGRÜNDUNG
Die Betroffenenrechte stehen in **Art. 15–22 DSGVO** (Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit, Widerspruch, keine rein automatisierte Entscheidung), dazu das Beschwerderecht bei der Aufsichtsbehörde (**Art. 77**). Verschlüsselung und Anonymisierung sind **technische Maßnahmen (TOM)**, keine Rechte. Berichtigung (**Art. 16**) und Einschränkung der Verarbeitung (**Art. 18**) sind dagegen echte Betroffenenrechte.

34 **Welche beiden der folgenden Aussagen sind falsch? Das Auskunftsrecht nach DSGVO …**

- [x] A … gilt nur gegenüber Behörden, nicht gegenüber Privatunternehmen.
- [x] B … wird durch die Aufsichtsbehörde ausgeübt.
- [ ] C … schließt das Recht auf eine Kopie der Daten ein.
- [ ] D … kann bei exzessiver Nutzung verweigert werden.

BEGRÜNDUNG
A ist falsch: Das Auskunftsrecht (**Art. 15 DSGVO**) gilt gegenüber **jedem** Verantwortlichen, auch gegenüber Unternehmen. B ist falsch: Die **betroffene Person** macht es selbst geltend – die Aufsichtsbehörde ist Anlaufstelle für Beschwerden (**Art. 77**). C stimmt (Kopie der Daten, **Art. 15 Abs. 3**), D ebenfalls: Bei offenkundig unbegründeten oder exzessiven Anträgen darf der Verantwortliche ein angemessenes Entgelt verlangen oder sich weigern (**Art. 12 Abs. 5 DSGVO**).

35 Die besonderen Kategorien des Art. 9 DSGVO wie z. B. biometrische Daten bezeichnen besonders schützenswerte personenbezogene Daten und untersagen grundsätzlich die Verarbeitung der bezeichneten Daten/Informationen. Es gibt aber Ausnahmen.

Welche Aussagen sind richtig?

- [x] **A** Die Einwilligung der betroffenen Person liegt in rechtsgültiger Form vor.
- [ ] **B** Die Datenverarbeitung dient dem berechtigten Interesse der Verantwortlichen Stelle.
- [x] **C** Die Verarbeitung ist aus arbeits- und sozialrechtlichen Gründen notwendig.
- [ ] **D** Die Verarbeitung dient zur Vertragserfüllung und -anbahnung oder eines Arbeitsvertrages.

BEGRÜNDUNG

Art. 9 Abs. 2 DSGVO enthält einen abschließenden Katalog von Ausnahmen, u. a. die **ausdrückliche Einwilligung** (lit. a) und die Erforderlichkeit für Pflichten aus dem **Arbeitsrecht und dem Recht der sozialen Sicherheit** (lit. b). Berechtigtes Interesse und Vertragserfüllung sind nur Rechtsgrundlagen nach **Art. 6 Abs. 1 lit. f bzw. lit. b** – für Daten nach Art. 9 reichen sie nicht aus.

36 **Welches ist im normalen Geschäftsbereich die sicherste und stärkste Rechtsgrundlage für die Verarbeitung personenbezogener Daten?**

- [ ] **A** Die Einwilligung, weil die von der betroffenen Person bewusst gegeben werden muss.
- [ ] **B** Berechtigte Interessen, weil die am breitesten ausgelegt werden können.
- [x] **C** Ein Vertrag, der auf Anfrage der betroffenen Person zustande kommt.

BEGRÜNDUNG

Ein **Vertrag** (**Art. 6 Abs. 1 lit. b DSGVO**) trägt die Verarbeitung, solange sie für den Vertrag erforderlich ist – er kann nicht wie eine Einwilligung jederzeit widerrufen werden. Die **Einwilligung** ist jederzeit widerrufbar (**Art. 7 Abs. 3**) und muss freiwillig, informiert und nachweisbar sein. **Berechtigte Interessen** (**lit. f**) erfordern eine Interessenabwägung, und die betroffene Person kann widersprechen (**Art. 21**) – breit auslegbar heißt nicht sicher.

37 Gemäß dem Grundsatz der Datensparsamkeit dürfen nach DSGVO nur die für die Zweckerfüllung benötigten Daten erhoben und verarbeitet werden.

Als Fachinformatiker haben Sie die Aufgabe, für einen Online-Büchershop eine entsprechende Eingabemaske zu entwerfen.

Die Maske soll zusätzlich zum Namen, zu Kontakt- und Zahlungsdaten noch Daten zum Einkommen, Alter und Familienstand enthalten.

Wie muss die Eingabemaske konditioniert werden?

- [ ] **A** Alle Eingabefelder können als Pflichtfelder deklariert werden, da die Daten auch anderweitig verwendet werden können.
- [ ] **B** Es müssen keine Pflichtfelder gekennzeichnet werden, damit die Kunden zum Ausfüllen aller Felder motiviert werden.
- [x] **C** Nur die für den Verkauf benötigten Daten dürfen als Pflichtfelder gekennzeichnet werden, die anderen müssen als optional erkennbar sein.

BEGRÜNDUNG

Datenminimierung (**Art. 5 Abs. 1 lit. c DSGVO**) und datenschutzfreundliche Voreinstellungen (**Art. 25 Abs. 2**): Für den Buchkauf nötig sind Name, Kontakt- und Zahlungsdaten – nur diese dürfen Pflicht sein. Einkommen, Alter und Familienstand braucht ein Buchshop nicht; sie dürfen höchstens freiwillig und klar als optional gekennzeichnet abgefragt werden. **Art. 13 Abs. 2 lit. e** verlangt zudem die Information, welche Angaben verpflichtend sind. A koppelt den Kauf an Daten, die dafür nicht nötig sind (Kopplungsverbot, **Art. 7 Abs. 4**), B verschleiert, welche Angaben Pflicht sind.

KAPITEL 3 · AUFGABEN 17–24

Wichtige Einzelthemen

17 **Welche der folgenden Aussagen ist richtig?**

- ☐ A Das Urheberrecht gilt nur für Werke der Musik und der bildenden Kunst, nicht aber für Computerprogramme.
- ☐ B Das Urheberrecht wird erst mit der Veröffentlichung des Werkes wirksam.
- ☑ C Das Urheberrecht erlischt 70 Jahre nach dem Tod des Urhebers.
- ☐ D Urheberrecht kann nur für Werke in Anspruch genommen werden, die mit dem Copyright-Zeichen © gekennzeichnet sind.

BEGRÜNDUNG

Nach **§ 64 UrhG** erlischt das Urheberrecht **70 Jahre nach dem Tod des Urhebers**. A ist falsch: Computerprogramme sind ausdrücklich geschützt (**§ 2 Abs. 1 Nr. 1, §§ 69a ff. UrhG**). B ist falsch: Der Schutz entsteht automatisch mit der **Schöpfung** des Werkes, nicht erst mit der Veröffentlichung. D ist falsch: Das ©-Zeichen ist in Deutschland keine Voraussetzung, sondern nur ein Hinweis.

18 **Damit eine natürliche oder juristische Person als „Verantwortlicher" oder „verantwortliche Stelle" gilt, muss sie Entscheidungsgewalt über zwei Dinge haben:**

- ☐ A Zeitpunkt und Art der Daten
- ☐ B Erhebung und Verwendung der personenbezogenen Daten
- ☑ C Mittel und Zweck der Verarbeitung von personenbezogenen Daten
- ☐ D Organisieren und Auslesen von personenbezogenen Daten

BEGRÜNDUNG

Art. 4 Nr. 7 DSGVO: Verantwortlicher ist, wer allein oder gemeinsam mit anderen über die **Zwecke und Mittel** der Verarbeitung entscheidet – also über das „Warum" und das „Wie/Womit". Erheben, Verwenden, Organisieren oder Auslesen (B, D) sind bloße Verarbeitungsvorgänge nach **Art. 4 Nr. 2 DSGVO**.

19 **Kennzeichnen Sie die falsche Aussage in Bezug auf ein Verzeichnis der Verarbeitungstätigkeiten (VVT).**

- ☐ A Die meisten Unternehmen sind zum Erstellen eines VVT verpflichtet.
- ☐ B Ein fehlendes VVT kann zur Verhängung eines Bußgeldes führen.
- ☐ C Die Mindestinhalte des VVT sind in der DSGVO definiert, die Form des VVT hingegen nicht.
- ☑ D Das VVT muss der Aufsichtsbehörde spätestens zum 2. Quartal eines jeden Jahres unaufgefordert vorgelegt werden.

BEGRÜNDUNG

Gesucht ist die falsche Aussage – das ist D. Das VVT muss der Aufsichtsbehörde nur **auf Anfrage** zur Verfügung gestellt werden (**Art. 30 Abs. 4 DSGVO**); eine jährliche Vorlagepflicht gibt es nicht. Die übrigen Aussagen stimmen: Die Ausnahme für Unternehmen mit weniger als 250 Beschäftigten (**Art. 30 Abs. 5**) greift kaum, weil fast jedes Unternehmen regelmäßig Daten verarbeitet (z. B. Lohnabrechnung); ein fehlendes VVT ist bußgeldbewehrt (**Art. 83 Abs. 4 lit. a**); die Inhalte stehen in **Art. 30 Abs. 1**, zur Form heißt es nur „schriftlich, auch elektronisch" (**Art. 30 Abs. 3**).

20 **Um im Unternehmen herauszufinden, was die Rechtsgrundlage und was die Löschfrist für die Arbeitszeiterfassung ist, wird welches Dokument diese Angaben enthalten?**

- [ ] A Personalakte
- [ ] B Stellenbeschreibung des Mitarbeiters
- [ ] C Tätigkeitsbericht des DSB
- [x] D Verzeichnis der Verarbeitungstätigkeiten (VVT)

BEGRÜNDUNG

Das **VVT** (**Art. 30 DSGVO**) beschreibt jede Verarbeitungstätigkeit – u. a. Zweck, Datenkategorien, Empfänger und, wenn möglich, die **Löschfristen** (**Art. 30 Abs. 1 lit. f**). Die Rechtsgrundlage ist dort zwar nicht ausdrücklich vorgeschrieben, wird in der Praxis aber mit dokumentiert (Rechenschaftspflicht, **Art. 5 Abs. 2**). Personalakte, Stellenbeschreibung und Tätigkeitsbericht des DSB enthalten diese Angaben nicht.

21 Die Verarbeitung personenbezogener Daten darf nur zweckgebunden erfolgen. Nach der Zweckerfüllung darf auch keine Identifizierung der betroffenen Person mehr möglich sein.

Welche Aussagen sind richtig?

- [x] A Nach der Zweckerfüllung müssen die personenbezogenen Daten sofort gelöscht oder anonymisiert werden, wenn keine gesetzlichen Regelungen entgegenstehen.
- [x] B Wenn die gesetzliche Aufbewahrungsfrist noch nicht abgelaufen ist, bleiben die Daten gespeichert, müssen aber nach der Zweckerfüllung durch ein geeignetes Verfahren dem allgemeinen Zugriff entzogen werden.
- [ ] C Solange die gesetzliche Aufbewahrungsfrist läuft, bleiben die Daten unverändert gespeichert, damit sie jederzeit eingesehen werden können.

BEGRÜNDUNG

Grundsatz der **Speicherbegrenzung** (**Art. 5 Abs. 1 lit. e DSGVO**): Ist der Zweck erfüllt, werden die Daten gelöscht oder anonymisiert (**Art. 17 Abs. 1 lit. a**). Steht eine gesetzliche Aufbewahrungspflicht entgegen (z. B. nach HGB oder AO), entfällt die Löschpflicht (**Art. 17 Abs. 3 lit. b**) – die Daten werden dann **gesperrt**, also in ihrer Verarbeitung eingeschränkt (**Art. 4 Nr. 3**), und dürfen nur noch für den Aufbewahrungszweck genutzt werden. C ist falsch: Die Daten dürfen nicht weiter frei einsehbar bleiben.

22 **Wann spricht man von einer Auftragsverarbeitung?**

- [ ] A Wenn ein Unternehmen die Daten von einer dritten Stelle bekommt und sie für eigene Zwecke verarbeitet.
- [ ] B Wenn ein weiteres Unternehmen über Mittel und Zwecke der Verarbeitung entscheidet.
- [x] C Wenn eine natürliche oder juristische Person, Behörde oder Einrichtung personenbezogene Daten im Auftrag für den Verantwortlichen (dieser Daten) verarbeitet.

BEGRÜNDUNG

Definition des Auftragsverarbeiters in **Art. 4 Nr. 8 DSGVO**: Er verarbeitet Daten **im Auftrag** und nach Weisung des Verantwortlichen; nötig ist ein **Auftragsverarbeitungsvertrag (AVV)** nach **Art. 28 DSGVO**. A beschreibt einen eigenen Verantwortlichen (eigene Zwecke), B ebenfalls: Wer über Zwecke und Mittel (mit)entscheidet, ist kein Auftragsverarbeiter (ggf. gemeinsame Verantwortung, **Art. 26**).

23 Die DSGVO enthält keine detaillierten Regelungen zur Verarbeitung von personenbezogenen Daten für Werbezwecke. Diese sind explizit im Gesetz gegen den unlauteren Wettbewerb (UWG) formuliert.

Welche Aussage ist richtig?

- ☐ A Da das UWG ein nationales deutsches Gesetz ist, müssen die Vorgaben der DSGVO im Hinblick auf Datenerhebung und Informationspflichten nicht beachtet werden.
- ☐ B Sobald es sich gem. UWG um Bestandskunden handelt, darf ich Werbung zustellen und muss nichts weiter beachten.
- ☑ **C Zusätzlich zu den Erlaubnistatbeständen des UWG müssen die Informationspflichten der DSGVO erfüllt werden.**

BEGRÜNDUNG

UWG und DSGVO gelten **nebeneinander**: Das UWG regelt, wann Werbung wettbewerbsrechtlich zulässig ist (**§ 7 UWG**); die DSGVO regelt die Datenverarbeitung dafür – inklusive Informationspflichten (**Art. 13/14**) und Widerspruchsrecht gegen Direktwerbung (**Art. 21 Abs. 2**). A ist falsch: Die DSGVO gilt als EU-Recht unabhängig vom UWG. B ist falsch: Selbst bei Bestandskunden ist E-Mail-Werbung nur unter Bedingungen erlaubt (**§ 7 Abs. 3 UWG**: eigene ähnliche Produkte, kein Widerspruch, Hinweis auf das Widerspruchsrecht).

24 **Innerhalb welches Zeitraums nach Bekanntwerden muss die verantwortliche Stelle meldepflichtige Datenschutzverstöße der Aufsichtsbehörde melden?**

- ☐ A Innerhalb 1 Monats
- ☑ **B Innerhalb von 72 Stunden**
- ☐ C Innerhalb von 3 Monaten

BEGRÜNDUNG

Art. 33 Abs. 1 DSGVO: Meldung an die Aufsichtsbehörde **unverzüglich und möglichst binnen 72 Stunden**, nachdem die Verletzung bekannt wurde – es sei denn, sie führt voraussichtlich zu keinem Risiko für die Betroffenen. Bei späterer Meldung muss die Verzögerung begründet werden. Bei **hohem Risiko** sind zusätzlich die Betroffenen zu benachrichtigen (**Art. 34**).

ZUM AUSWENDIGLERNEN

Für die Prüfung

Zahlen und Fristen

72 Stunden	Meldung einer Datenpanne an die Aufsichtsbehörde (Art. 33 Abs. 1 DSGVO)
70 Jahre	Schutzdauer des Urheberrechts nach dem Tod des Urhebers (§ 64 UrhG)
auf Anfrage	VVT an die Aufsichtsbehörde – keine jährliche Vorlagepflicht (Art. 30 Abs. 4 DSGVO)
250 Beschäftigte	Grenze der VVT-Ausnahme (Art. 30 Abs. 5) – greift in der Praxis kaum

Begriffe aus Art. 4 DSGVO

Art. 4 Nr. 1	**Personenbezogene Daten**	identifizierte oder identifizierbare natürliche Person – direkt oder indirekt
Art. 4 Nr. 7	**Verantwortlicher**	entscheidet über **Zwecke und Mittel** der Verarbeitung
Art. 4 Nr. 8	**Auftragsverarbeiter**	verarbeitet **im Auftrag** des Verantwortlichen, mit AVV (Art. 28)

Verwechslungsgefahren

Art. 9 vs. Art. 10	rassische und ethnische Herkunft, politische Meinung, Religion/Weltanschauung, Gewerkschaftszugehörigkeit, genetische und biometrische Daten, Gesundheit, Sexualleben/sexuelle Orientierung → **Art. 9**. Straftaten und Führungszeugnis → **Art. 10**. Bankdaten → keins von beiden.
Rechte vs. Maßnahmen	Auskunft, Berichtigung, Löschung, Einschränkung, Übertragbarkeit, Widerspruch, Beschwerde sind **Rechte**. Verschlüsselung, Pseudonymisierung, Anonymisierung sind **TOM**.
Art. 6 vs. Art. 9 Abs. 2	Vertrag und berechtigtes Interesse reichen für normale Daten – für besondere Kategorien braucht es eine Ausnahme aus Art. 9 Abs. 2 (z. B. ausdrückliche Einwilligung, Arbeits- und Sozialrecht).
Verantwortung vs. Beratung	Verantwortlich ist die **oberste Leitung**; der DSB berät und überwacht nur.
Datenschutz vs. Datensicherheit	Schutz der **Person** (qualitativ, Rechte und Freiheiten) vs. Schutz **aller Daten** (quantitativ, Schadenshöhe × Eintrittswahrscheinlichkeit).
Löschen vs. Sperren	Zweck erfüllt → löschen oder anonymisieren; Aufbewahrungsfrist läuft noch → sperren (Einschränkung der Verarbeitung).
Widerruf vs. Widerspruch	Eine Einwilligung wird **widerrufen** (Art. 7 Abs. 3), einer Verarbeitung wird **widersprochen** (Art. 21).

PRÜFUNGSTIPP · NEGATIVFRAGEN

Fünf der 21 Fragen fragen nach der **falschen** bzw. **nicht** zutreffenden Aussage: Kap. 1 Aufg. 13, Kap. 2 Aufg. 32, 33 und 34 sowie Kap. 3 Aufg. 19. Dort werden die falschen Aussagen angekreuzt – Signalwort beim Lesen markieren.